PROJECT PROPOSAL

oneM2M 양방향 보안 게이트웨이

통신의 신뢰도와 장치 상태를 연결하는 실행 전 안전 정책 서비스

공통 허브	안전 정책 서비스	실증 플랫폼
HTTP · MQTT	데이터 신뢰 · 장치 상태	도어락 / 난방 모형
상향 / 하향 통신 보호	실행 전 판단과 감사	비교 실험과 고객 실증

연결의 신뢰를 확인하고 실행의 안전을 판단하다

Mobius4 기반 기술·사업 개발 제안서

작성 기준 2026 년 9 월 22 일 | 버전 1.0

본 문서는 개발 제안 단계의 자료다. 성능·일정·예산·판매 가격은 별도 표시한 계획 가정이며, 구현 완료나 제품 인증을 의미하지 않는다.

READING GUIDE

제안서 구성

기술 검토와 사업 검토가 같은 근거를 공유하도록 구성했다. 핵심 제안은 01~04, 구현은 05~11, 시장·특허는 12~16, 실증·추진은 17~21 에서 다룬다.

장치와 서버를 함께 보호하는 공통 허브 3
인증 성공과 안전한 실행은 서로 다른 판단이다 4
oneM2M 보안을 재사용하고, 업무 안전 조건을 더한다 5
첫 제품은 oneM2M 운영 환경에 집중한다 6
네트워크 검사와 의미 기반 판단을 함께 배치한다 7
IoT → 서버: 요청량과 데이터 신뢰도를 관리한다 8
서버 → IoT: 권한 확인 후 실행 조건을 검사한다 9
Mobius4 의 공통 요청 경로에 정책을 연결한다 10
정책은 장치 프로필과 운영 조건으로 구성한다 11
운영자는 기술 로그보다 상태와 조치부터 본다 12
키트는 보안 효과를 눈으로 확인하는 실험 장치다 13
비슷한 기능은 있다. 차이를 시험으로 보여줘야 한다 14
공개 실적은 수요의 참고 근거이며 제품 마진은 아니다 15
유료 실증으로 가치와 운영 비용을 함께 확인한다 16
oneM2M·안전·AI 라는 조합만으로 신규성을 주장할 수 없다 17
발명 후보를 구현 가능한 절차로 좁힌다 18
기본 보안·IPS·제안 기능을 같은 조건에서 비교한다 19
16 주 안에 실증 가능한 범위를 완성한다 20
인력 중심의 MVP 예산을 산정한다 21
기술·사업의 불확실성을 진행 기준으로 관리한다 22
개발의 목표는 보안 효과와 고객 가치를 입증하는 것이다 23
대표 선행문헌 5 건의 범위를 구분한다 24
표준·코드·보안 제품 25
시장·실적·문헌 26
특허·구현·운영 참고 27

01 / 제안 요약

장치와 서버를 함께 보호하는 공통 허브

Mobius4 기반 oneM2M 서비스에 장치별 안전 정책을 더해, 위험한 요청이 실제 동작으로 이어지기 전에 판단하는 보안 서비스를 제안한다.

항목	제안 내용
핵심 제품	oneM2M 요청·응답·알림을 해석하는 양방향 보안 허브와 장치별 안전 정책 서비스
보호 대상	IoT → 서버의 데이터·요청, 서버/앱 → IoT 의 제어, 허브를 통과하는 장치 간·외부 통신
우선 고객	oneM2M 을 운영하는 시설·공공 IoT 사업자와 시스템 통합 사업자
차별화 가설	센서 데이터의 신뢰 상태와 장치 상태를 제어 판단에 함께 사용하고, 차단 이유를 운영자가 이해하게 제공
키트의 역할	도어락·난방 모형을 이용한 시연, 재현 가능한 시험, 고객 실증용 테스트베드
개발 범위	16 주 MVP: HTTP/MQTT, 정책 엔진, 감사·알림, 두 종류 장치 프로필, 비교 실험
투자 가정	4 명·16 주, 총 1 억 560 만 원의 계획 예산. 견적 또는 확정 투자액이 아님

개발 착수의 논리

인증된 장치도 침해될 수 있고, 권한을 가진 앱도 잘못된 명령을 보낼 수 있다. 기존 인증·접근제어·IPS 를 유지하면서, 서비스가 아는 장치 상태와 실행 조건을 보안 판단에 연결한다. 다만 유사 기능을 가진 제품과 특허가 이미 존재하므로, 신규성이나 고객의 지불 의사를 전제로 사업성을 주장하지 않는다.

최종 실증 질문

기존 oneM2M 보안과 IPS 만 적용했을 때보다 위험 동작을 더 줄이면서, 정상 운영의 오차단과 지연을 수용 가능한 수준으로 유지할 수 있는가?

02 / 문제와 필요성

인증 성공과 안전한 실행은 서로 다른 판단이다

보안의 범위를 명령 차단에만 두지 않는다. 잘못된 데이터가 서버의 판단을 바꾸고, 그 판단이 다시 장치 동작으로 돌아오는 전체 흐름을 다룬다.

상황	기존 보호의 역할	추가로 판단할 내용
감염된 센서가 요청을 폭주	접속 인증, 네트워크 IPS, HTTP 제한	장치·테넌트·작업별 할당량과 MQTT 요청량
정상 계정이 잘못된 센서값 전송	전송 무결성, 자원 접근 권한	값의 단위·시각·연속성·다른 센서와의 관계
허용된 앱이 위험한 제어 요청	요청자 인증과 ACP 권한 검사	현재 상태에서 가능한 동작인지, 근거 데이터가 신선한지
알림·외부 전송 기능 악용	프로토콜·자원별 접근 제어	목적지 허용 목록, 재시도 상한, 외부 전송 정책

필요성은 고객 환경에서 확인한다

장치가 모두 독립 안전장치를 갖추고 서버의 업무 규칙이 충분하다면 별도 허브의 가치가 작을 수 있다. 반대로 여러 제조사 장치를 함께 운영하며 정책 변경·감사·격리가 분산된 환경이라면 공통 정책 계층의 효용을 검증할 가치가 있다.

첨부 논문은 IoT 보안 문제와 인증·암호화·플랫폼·물리 보안의 필요성을 정리한 2020 년 문헌조사다. 제안의 배경으로 사용하되, 논문에 인용된 과거 비율을 현재 시장이나 Mobius4 의 취약 비율로 확대하지 않는다. [S12]

주장 범위

"IoT → 서버 공격이 대부분"이라는 비율은 확인하지 못했다. 이 제안은 공격 빈도 순위가 아니라 양쪽 방향 모두 피해가 발생할 수 있다는 위협 모델에 근거한다.

03 / 기존 기능과 역할

oneM2M 보안을 재사용하고, 업무 안전 조건을 더한다

표준의 보안 요구사항, Mobius4 의 실제 구현, 이번에 개발할 기능을 분리한다.

계층	이미 제공하거나 재사용할 기능	이번 개발의 책임
oneM2M 표준	보안 연결·인증·접근제어·기밀성/무결성, DoS·재전송 등 보안 요구	표준이 자동으로 보장한다고 가정하지 않고 배포 설정과 적용 여부 검증
Mobius4 CSE	HTTP/MQTT 바인딩, 자원 모델, ACP, 구독·알림	공통 요청 경로·원격 전달·실행 어댑터에 정책 집행 연결
방화벽 / Suricata	통신 구간 제한, 알려진 공격 규칙, MQTT 필드·평문 메시지 검사	네트워크 구성, 규칙 튜닝, 경보 연계와 우회 경로 차단
장치 프로필 / 정책	서비스가 정의해야 하는 영역	명령·단위·상태 전이·데이터 신뢰도·시간 조건·차단 사유
운영 서비스	각 제품의 로그·알림 기능	장치·정책·센서 근거를 연결한 사건 이력과 격리·복구 절차

oneM2M 은 상호 인증과 보안 연결, 접근 권한, 종단 간 보호를 다루며, 보안 요구사항에는 가용성과 재전송·신원 오용 등도 포함한다. 그러나 요구사항의 존재와 특정 제품에서의 구현·활성화는 같은 뜻이 아니다. [S02, S03]

일부 oneM2M 연동 규격의 blocking subscription 은 외부 장치 작업과 자원 갱신을 조율하는 수단이다. 그 명칭만으로 범용 침입 차단이나 장치별 안전 정책이 이미 구현됐다고 해석하지 않는다. [S19]

설계 원칙

표준 보안을 대체하지 않는다. 인증·권한 검사를 통과한 요청에 대해서도 장치별 실행 조건을 추가 확인한다.

04 / 제품 범위

첫 제품은 oneM2M 운영 환경에 집중한다

판매 대상은 공통 보안 허브와 정책 운영 서비스다. 센서 키트는 기능을 설명하고 검증하는 수단으로 사용한다.

구분	MVP 포함	후속 확장 또는 제외
통신	Mobius4 HTTP/MQTT 의 oneM2M JSON 요청과 관련 알림	일반 웹 전체 보호, 모든 산업 프로토콜 자동 지원 제외
정책	장치 신원·자원·빈도·값·상태·데이터 신선도 규칙	학습 기반 자동 차단은 규칙 성능 확보 후 별도 평가
장치	도어락 모형, 난방 모형의 프로필 2 종	모든 상용 도어락·보일러에 즉시 호환된다는 약속 제외
보호 구간	허브/CSE/어댑터를 통과하도록 구성한 경로	별도 셀룰러·직접 연결 등 통제하지 못하는 경로는 범위 밖
관리	등록, 정책 버전, 감사 로그, 알림, 격리·복구	24 시간 관제 인력과 인증된 물리 안전 시스템 제공 제외

제품 구성

- 현장 허브: 통신 제어, 캐시된 정책, 장치 상태 확인, 로컬 감사 버퍼.
- 중앙 관리: 정책 작성·승인·배포, 장치별 상태, 사건 이력, 사이트별 운영 현황.
- 장치 프로필: 제어 명령 스키마, 단위, 안전 범위, 실행 전제조건, 비상 동작 정의.
- 실증 키트: 센서·제어 모형·공격 시나리오 생성기·실행 확인 로그.

우선 진입점

기존 oneM2M 시스템에서 특정 장치군을 제한적으로 보호하는 B2B 실증을 먼저 진행한다. 소비자 대상 범용 보안 키트 양산은 실증 이후의 별도 사업 판단으로 둔다.

05 / 전체 구조

네트워크 검사와 의미 기반 판단을 함께 배치한다

암호화된 통신은 신뢰할 수 있는 종단에서 해석하고, 최종 실행 직전에는 현장 상태를 다시 확인한다.

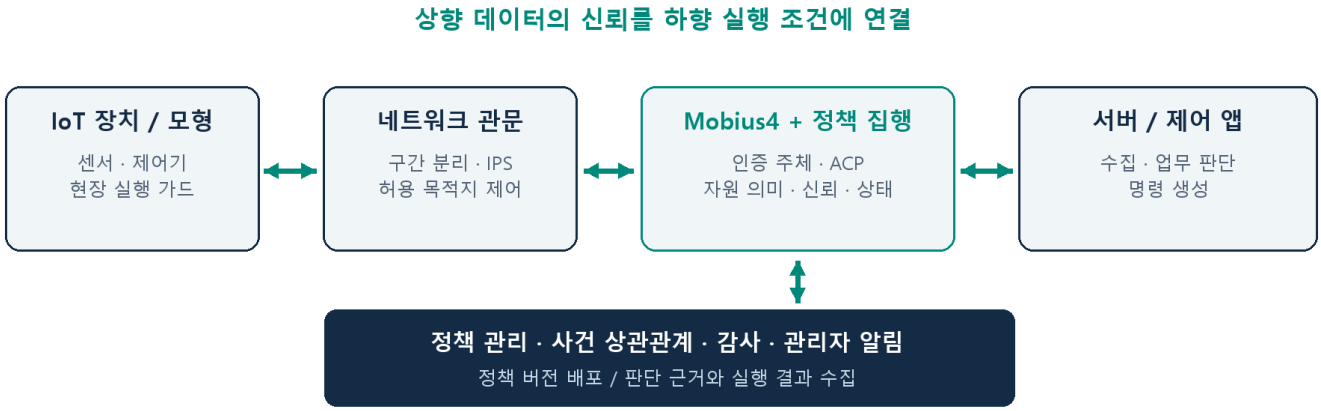


그림 1. 개념 배치도 — 허브를 경유하는 경로와 실제 실행 지점에 집행

구성 요소	기능과 경계
네트워크 관문	장치망 분리·목적지 제한·Suricata IPS. 실제 경유 트래픽만 집행 가능.
신원 확인 / 바인딩	상호 TLS 의 클라이언트 인증 또는 브로커 인증 결과를 장치 ID·테넌트·oneM2M Originator 와 연결. 헤더값만 신원으로 신뢰하지 않음.
CSE 정책 집행	HTTP/MQTT 공통 요청 정규화, ACP 이후 장치 정책, 원격 전달 전 별도 유입 정책.
현장 실행 가드	명령 만료·중복·장치 현재 상태를 확인하고 실제 동작 직전 재판단.
정책 / 감사 서비스	버전 관리·역할별 권한·판단 이유·상관관계 ID·운영 알림과 복구 이력.

TLS 통과 지점에 단순 IPS 를 두는 것만으로 암호화 본문을 읽을 수 없다. CSE 내부나 허용된 TLS 종단 이후에 의미 기반 검사를 연결한다. 종단 간 암호화로 본문이 보이지 않는 구간은 메타데이터 검사만 가능하며, 단말 연동 없이는 내용 판단을 보장하지 않는다. [S01, S04, S05]

06 / 상향 보호

IoT → 서버: 요청량과 데이터 신뢰도를 관리한다

서버 가용성을 지키는 차단 정책과 센서 데이터의 불확실성을 다루는 정책을 구분한다.

위협 / 오류	판단 근거	처리
장치별 요청 폭주	인증 장치·테넌트·작업별 허용량	초과 요청 제한, 다른 장치의 처리량 확보, 운영 알림
권한 밖 자원 조작	장치 ID 와 허용 자원/작업의 매핑	ACP 와 추가 범위 정책으로 거부
비정상 형식·과대 본문	메시지 크기, 스키마, 단위·타입	처리 전 거부, 요약 원인 기록
오래되거나 중복된 데이터	수집 시각, 시퀀스, 수신 시각, 중복 키	재시도와 재전송 공격 구별; 상태 갱신 중복 방지
센서 위조 의심	변화율, 타 센서, 장치 상태, 교정 정보	불확실 상태 표시, 자동제어 입력 제한, 원본·경보 유지
외부 전송 / 횡적 이동	대상 주소·포트·도메인과 네트워크 구역	허용된 목적지만 통신; 허브 밖 경로는 별도 통제 필요

센서값의 진위를 단정하지 않는다

인증은 송신 주체와 전송 무결성을 확인하는 수단이며, 물리 측정값이 참이라는 증거는 아니다. 값이 급변하면 센서 고장·통신 오류·실제 위험·공격을 함께 고려한다. 독립 센서나 장치 자체 진단과 교차 확인할 수 없으면 "의심" 상태로 표시한다.

예외 처리

높은 온도나 가스 농도를 단지 이상값이라는 이유로 삭제하거나 경보에서 제외하지 않는다. 위험 경보를 유지하고, 불확실한 데이터에 의존하는 자동 동작만 사전에 정한 정책으로 제한한다.

07 / 하향 보호

서버 → IoT: 권한 확인 후 실행 조건을 검사한다

정상 형식의 명령이라도 현재 장치 상태, 명령 순서, 근거 데이터가 부적절하면 실행을 보류하거나 거부한다.

검사 순서	예시 질문	설계
① **주체 / 권한**	이 앱이 이 장치를 제어할 수 있는가?	인증 주체 매핑 + ACP + 장치별 권한
② **명령 의미**	이 장치에 유효한 명령·단위·범위인가?	버전이 있는 장치 프로필로 해석
③ **현재 조건**	인터록 상태와 명령 순서가 허용되는가?	현장 상태와 안전한 상태 전이 확인
④ **근거 데이터**	제어에 사용한 센서 정보가 신선하고 신뢰 가능한가?	신뢰 상태·수집 시각·정책 버전 연결
⑤ **최종 실행**	검사 후 상태가 바뀌거나 같은 명령이 반복됐는가?	실행 직전 재검증, 만료시간·멱등성 키, 장치 승인 결과

CSE 자원 생성 성공과 실제 장치 동작 성공은 다르다. 명령 콘텐츠가 저장된 뒤 구독 알림으로 전달되는 구조에서는, 저장 단계의 정책과 장치 어댑터의 최종 실행 검사를 연결한다. 허브가 차단한 명령이 다른 앱·브로커 경로로 실행되지 않도록 우회 경로도 통제한다.

통신 장애 시 모든 동작을 일괄 허용하거나 차단하지 않는다. 일반 제어와 비상 정지·현장 수동 조작을 구분하고, 장치별 안전 설계에 따라 기본 동작을 정의한다. 제안 서비스는 제조사 안전장치나 인증된 인터록을 대체하지 않는다.

핵심 차별화 가설

상향 데이터의 신뢰 상태가 하향 제어의 허용 조건에 직접 반영되며, 동일 사건에서 "무엇 때문에 차단됐는지"를 설명할 수 있다.

08 / 구현 계획

Mobius4 의 공통 요청 경로에 정책을 연결한다

기준 코드는 v4.24.5, 커밋 3da4d8523694b5077e348ab1c9e769fb3a30df24 다. 실제 배포 전 업스트림 변경을 다시 검토한다. [S01]

위치	확인 사항	제안 변경
bindings/http.js / mqtt.js	두 바인딩 모두 prim_handling 으로 합류	바인딩별 인증 결과를 공통 보안 컨텍스트로 전달
cse/reqPrim.js 유입부	원격 요청은 로컬 ACP 보다 앞에서 전달될 수 있음	원시 본문 크기는 HTTP 바인딩·브로커에서 먼저 제한; 전달 분기 전 인증 장치 할당량·목적지 정책 적용
cse/reqPrim.js 로컬 처리	대상 자원 해석과 ACP 이후 작업 수행	권한 검사 유지; 부작용 전 장치 의미·상태 정책 적용
그룹 / 알림 / 전달	그룹 fan-out, 구독 알림, 원격 CSE 등 별도 경로	그룹 구성원 검사, 외부 목적지 제한, 알림 실행 경로 검증
장치 실행 어댑터	CSE 밖에서 실제 동작 발생	서명/인증된 명령 컨텍스트와 현장 상태 재검증
로그 / 운영	요청 본문·신원 정보가 기록될 수 있음	민감값 마스킹, 이유 코드, 정책 버전과 감사 이벤트 분리

배포 설정도 실증 범위에 포함

소스 기본 설정과 Docker Compose 의 보안 설정은 같지 않다. Compose 는 Helmet·HTTP rate limit 을 기본 활성화하지만 장치별·MQTT 할당량을 대체하지 않는다. 저장소 TLS 문서는 클라이언트 인증서와 Originator 를 자동 결합하지 않는다고 설명하므로, HTTPS 활성화만으로 장치 인증이 완성됐다고 보지 않는다. [S01]

라이선스 검토

Mobius4 의 BSD 3-Clause 고지·조건을 유지한다. Suricata·규칙·추가 라이브러리의 배포 및 상용 사용 조건은 구성 확정 시 별도 목록으로 검토한다.

09 / 정책 모델

정책은 장치 프로필과 운영 조건으로 구성한다

oneM2M 은 전달 구조를 제공하지만, 콘텐츠가 어떤 물리 동작을 뜻하는지는 장치 프로필이 정의해야 한다.

정책 필드	난방 모형 예시 — 제품 안전 규격이 아님
profile / version	heater-demo / 1.0; 명령 스키마와 단위 버전 고정
subject / target	인증된 제어 앱, 지정 테넌트, /site-a/heater-01 명령 자원
command	set_temperature; 단위 °C; 모형용 허용 범위 18~28
preconditions	현장 인터록 정상, 상태 정보 5 초 이내, 입력 센서 trusted
freshness / dedup	명령 유효기간 3 초, command_id 실행 이력 영속화로 중복 억제; 실행 결과 불명 시 자동 재실행 금지
effect / reason	거부 시 STALE_STATE 또는 UNTRUSTED_INPUT 등 이유 제공
execution check	장치 어댑터에서 상태 버전 재확인 후 실행 승인
audit	상관관계 ID, 요청자, 프로필·정책 버전, 판단·실행 결과 기록

정책 수명주기

초안 작성 → 기록된 정상 트래픽으로 재생 검사 → 관찰 모드 → 담당자 승인 → 제한된 장치에 적용 → 차단 모드 확대 순으로 배포한다. 변경 이력과 이전 버전을 남겨 오차단 시 되돌릴 수 있게 한다. 고위험 정책의 작성 권한과 승인 권한을 분리한다.

예시 수치의 의미

온도·시간 기준은 시험 시나리오용 가정이다. 실제 장치에서는 제조사 사양, 현장 위험 분석, 수집 주기에 맞춰 다시 결정해야 한다. 범용 안전 기준으로 사용하지 않는다.

10 / 사용자 경험과 운영

운영자는 기술 로그보다 상태와 조치부터 본다

전문 운영자는 정책을 관리하고, 일반 사용자는 보호 상태와 필요한 행동을 이해할 수 있게 한다.

화면	표시 내용	운영 동작
전체 현황	보호 중 / 확인 필요 / 제어 제한 / 연결 끊김	장치별 마지막 통신과 보호 범위 확인
사건 상세	"센서 정보가 오래되어 난방 명령을 보류했습니다."	대상 장치, 원인, 영향, 확인 방법 제공
연결된 근거	센서 수신 → 신뢰도 변경 → 명령 요청 → 판단 → 실행 결과	누가·언제·어떤 정책으로 처리했는지 추적
정책 관리	장치 종류별 권장 템플릿과 적용 전 영향 미리보기	전문가가 범위·조건 조정, 역할별 승인
격리 / 복구	제어만 제한, 외부 통신 제한 등 단계별 조치	비상 기능 유지 확인, 원인 해소 후 검증된 복구

경보 피로와 개인정보를 함께 줄인다

같은 원인의 반복 경보는 사건 단위로 묶고, 영향이 큰 사건을 먼저 표시한다. 예를 들어 100 회의 차단 요청을 100 개 알림으로 보내는 대신 "장치 A 의 비정상 요청 100 회 제한"으로 집계한다. 전송 실패는 재시도와 로컬 버퍼로 보완하며, 감사 저장 실패가 제어 안전성에 주는 영향도 시험한다.

감사 로그는 최소한의 식별자·판단 근거·버전을 기록한다. 출입 기록, 위치 정보, 장치 키와 원본 본문의 수집·보관 범위를 구분하고 접근 권한과 보존기간을 운영 계약에서 확정한다.

알림 예시

[제어 제한] 난방 모형 01 의 상태 정보가 8 초 동안 갱신되지 않아 설정 변경을 보류했습니다. 현재 장치 상태를 확인한 후 재시도하세요. 비상 정지 경로는 별도 정책에 따라 유지됩니다.

11 / 시연과 검증 플랫폼

키트는 보안 효과를 눈으로 확인하는 실험 장치다

실제 잠금장치나 연료 계통에 직접 연결하기 전에, 저전압 모형에서 동작 결과까지 검증한다.

구성	도어락 모형	난방 모형
입력	문 열림 센서, 상태 스위치, 인증된 제어 앱	온도 센서 또는 시뮬레이터, 인터록 스위치
출력	서보·LED 잠금 상태 모형	LED·저전압 팬 등 열원 대신 동작 표시
정상 시연	허용된 사용자와 상태에서 잠금/해제	신선한 센서값과 허용 조건에서 설정 변경
공격 / 오류 시연	중복 해제, 다른 장치 자원 접근, 요청 폭주	위조 의심 센서값, 오래된 상태, 범위 밖 명령
판정 증거	실제 모형 실행 횟수와 감사 사건 비교	위험 동작 미실행과 정상 경보 유지 확인

대표 시나리오: 데이터 오염에서 제어까지

- ① 정상 동작을 먼저 기록하고 센서·명령·실행 로그에 같은 사건 ID 를 연결한다.
- ② 센서에 급격한 변화 또는 오래된 값을 입력해 데이터 신뢰 상태를 낮춘다.
- ③ 서버가 해당 데이터를 근거로 제어 요청을 생성하도록 시험한다.
- ④ 게이트웨이는 신뢰 조건 위반을 설명하고, 실행 가드는 실제 모형 동작을 제한한다.
- ⑤ 독립 상태 확인 후 정상 복구하고, 정상 데이터에 대한 오차단도 함께 측정한다.

키트 범위

시연 키트는 제품 안전 인증이나 실제 설비 적용 승인을 뜻하지 않는다. 상용 장치 연동은 제조사 인터페이스·현장 인터록·설치 조건 확인을 거쳐 별도 수행한다.

12 / 경쟁 대안

비슷한 기능은 있다. 차이를 시험으로 보여줘야 한다

비교 기준은 "보안 기능이 있는가"가 아니라, oneM2M 자원과 장치 상태를 연결하는 데 필요한 통합 비용과 운영 효과다.

대안	이미 제공되는 가치	우리의 검증 과제
oneM2M + Mobius4	인증·접근제어·자원 관리·알림	기본 보안 위에 정책을 추가할 때 실제 위험 동작 감소 여부
Suricata	IPS 및 MQTT 필드·메시지 규칙 검사	일반 규칙만으로 가능한 범위와 상태 기반 판단의 추가 효과
Fortinet OT 보안	산업 프로토콜의 명령·값 검사와 IPS 정책	oneM2M 프로필 통합·운영 편의에서 가치가 생기는지
Nozomi Networks	OT/IoT 자산 가시성·위협/이상 탐지	탐지·응답 연계와 우리 실행 직전 집행의 차이·보완성
Firewalla	장치 행동·허용 목적지에 따른 통신 제어	범용 네트워크 정책 대비 장치 의미·상태를 쓰는 효용
AWS IoT Device Defender	장치 보안 감사, 기존 고객의 행동 기반 Detect	클라우드 탐지와 현장 실행 가드의 역할 비교

AWS Device Defender Detect 는 2026 년 8 월 31 일부터 신규 고객 접근이 종료되어 maintenance mode 에 들어갔다. 기존 고객은 계속 사용할 수 있으며 Audit 는 계속 제공된다. 현시점 도입 대안과 과거 기능 비교를 구분한다. [S06]

Suricata 가 MQTT 내용을 읽을 수 없다는 주장은 잘못이다. 평문 메시지와 토픽에 규칙을 적용할 수 있다. 제안의 추가 가치는 프로토콜 해독 자체가 아니라 인증된 장치·자원·정책 버전·현재 상태·센서 신뢰를 연결해 일관되게 집행하는 데서 검증해야 한다. [S04, S05, S07, S08, S20]

차별화 문장

"최초의 IoT 보안 허브" 대신 "oneM2M 운영 환경에서 데이터 신뢰와 실행 조건을 연결하는 정책 서비스"로 제안한다.

13 / 시장 근거와 수익성

공개 실적은 수요의 참고 근거이며 제품 마진은 아니다

회사 전체의 매출·가입자·이익률과 특정 IoT 보안 제품의 판매량·이익률을 분리한다.

기업 / 기준	공개 지표	해석 범위
Verisure / FY2025	매출 €3,745.4m 조정 EBIT 마진 25.4% 연말 약 620 만 고객; Q4 신규 설치 22.4 만 건	보안 구독 운영의 인접 사례. 우리 제품의 판매량이나 시장 규모가 아님.
Allegion / FY2025	매출 US$4,067.3m GAAP 영업이익률 21.1% 개별 스마트락 수량·마진 미확인	잠금·출입 관련 기업 전체 실적. 스마트 도어락 SKU 마진이 아님.
Resideo / FY2025	매출 US$7,472m 매출총이익률 29.4% 영업이익률 8.12% (계산)	FY2025 전사 기준(유통 포함). 개별 보일러 보안 키트 판매량·마진 미확인.

표의 m 은 백만 단위다. 통화는 공시 통화를 유지한다. Verisure 952.9÷3,745.4=25.4%, Allegion 859.5÷4,067.3=21.1%, Resideo 총이익 2,196÷7,472=29.4%·영업이익 607÷7,472=8.12%다. 서로 다른 이익률을 순위로 비교하지 않는다. Resideo 의 GAAP 순손실은 US$527m 이므로 총이익을 순이익으로 해석해서는 안 된다. [S09, S10, S11]

현재 확인하지 못한 것

- oneM2M 의미 기반 양방향 보안 허브의 독립 시장 규모와 유료 고객 수.
- 비교 제품의 개별 판매 수량, oneM2M 관련 매출, 제품별 원가·이익률.
- 고객이 추가 허브의 운영 복잡성을 감수하면서 지불할 가격.

사업성 판단

인접 기업 실적은 보안·연결 장치 사업의 존재를 보여준다. 우리 사업의 매출 전망은 고객 수·계약 조건·구축 비용을 별도로 검증한 뒤 산정한다. 공개 자료만으로 매출 목표를 확정하지 않는다.

14 / 고객 검증과 사업 모델

유료 실증으로 가치와 운영 비용을 함께 확인한다

첫 고객은 이미 oneM2M 을 운영하고, 정책 분산이나 사고 대응의 불편을 측정할 수 있는 조직으로 좁힌다.

단계	실행 내용	다음 단계 진입 기준 — 계획
문제 인터뷰	운영자·통합 사업자 10 곳; 장치 수, 장애, 정책 변경 시간, 기존 대안 조사	3 곳 이상이 구체적인 운영 문제와 실증 범위를 확인
기술 실증	2 개 현장 후보의 데이터 흐름·TLS·우회 경로·장치 API 확인	최소 1 곳에서 통제 가능한 경로와 제조사 연동 조건 확보
유료 파일럿	사이트 구축비 + 정책·운영 월 요금으로 제안	지불 의사, 실증 합의, 지원 범위와 책임 경계 확인
반복 판매	동일 프로필을 다른 현장에 배포	두 번째 현장의 연동 노력과 월 지원 시간이 충분히 감소

가격·단위 경제성 예시 — 실측 전 가정, VAT 별도

항목	가정 매출	직접원가 가정	매출총이익
사이트 최초 구축	300 만 원	180 만 원	120 만 원 / 40%
월 서비스 / 사이트	50 만 원	25 만 원	25 만 원 / 50%
첫 12 개월 합계	900 만 원	480 만 원	420 만 원 / 46.7%

월 직접원가 25 만 원은 호스팅 6 만·지원 12 만·유지보수 배분 7 만 원의 가정이다. 구축원가 180 만 원은 연동 140 만·현장 장비 배분 40 만 원이다. 첫해 합계는 구축 1 회와 월 서비스 12 개월을 모두 제공했을 때이며, 실제 계약 시점과 장치 수·지원량에 따라 달라진다.

월 직접원가가 15 만/25 만/35 만 원이면 매출총이익률은 70%/50%/30%다. 연구개발·영업·관리·세금 등을 제외한 값이므로 영업이익률이나 순이익률이 아니다. 가격은 시장 검증 전 가설이며 부품 견적을 의미하지 않는다.

15 / 선행특허 검토

oneM2M·안전·AI 라는 조합만으로 신규성을 주장할 수 없다

관련 등록·공개 특허의 기술 요소를 비교하고, 자체 구현의 차이를 청구항 단위로 검토해야 한다.

문헌	주요 기술 요소	제안과의 관계
KR102863685B1	oneM2M 변환, 현장별 경량 AI, 위험 기준에 따른 데이터 선택 전송, GUI 정책	oneM2M 안전 게이트웨이라는 넓은 개념과 가까움. 상세 청구항 대조 필요.
KR102889055B1	학습 손실·확률 기준에 따른 라우터별 AI 모델 할당과 그룹 모델 사용	장치/라우터 관찰과 이상 탐지 계층이 중첩할 수 있음.
KR102419687B1	정규화·주성분 분석 등 데이터 기반 IoT 이상 탐지	이상 탐지 기법 자체를 발명으로 제시하기 어려움.
US11616795B2	통신 통계를 이미지로 변환해 장치 persona 학습·분류 및 대응	네트워크 장치 행동 분류와 관련; 구체 방법을 구분해야 함.

이 표는 대표 선행문헌의 예비 조사다. 출원인·우선일·문헌 간 관계와 링크는 부록에 정리한다. Google Patents 의 상태 표시는 법적 권리 존속이나 한국에서의 실시 자유를 확정하지 않으므로, 사업화 전 등록원부·패밀리·독립항을 확인한다. [S13–S16]

제안서의 특허 표현

"특허가 없다", "침해하지 않는다", "출원하면 등록된다"는 결론을 내리지 않는다. 경쟁 특허가 있다는 이유만으로 구현 불가라고 단정하지도 않는다.

16 / 지식재산 전략

발명 후보를 구현 가능한 절차로 좁힌다

넓은 아이디어보다 데이터 처리 단계, 판단 근거와 실행 보장 방법의 구체적인 결합을 검토한다.

검토 후보 — 신규성 미확인	구체화할 내용	확보할 증거
신뢰 상태의 제어 연계	oneM2M 자원별 데이터 신뢰 상태를 명령 전제조건으로 전달하는 구조	기존 방식과 다른 단계·자료구조, 정상/공격 비교 결과
검사-실행 간 일관성	정책 버전·상태 버전·유효기간을 묶어 실행 직전 확인하는 절차	상태 변경·지연·중복에서 위험 동작을 막은 재현 로그
공통 경로 집행	HTTP/MQTT·원격 전달·그룹·알림의 판단 일관성 유지	우회 시험 결과와 요청-실행 상관관계
프로필 배포·검증	장치 안전 프로필의 재생 검사, 단계 적용, 롤백	새 현장에 적용할 때의 통합 시간 감소와 오차단 변화

출원과 구현 검토 절차

- 핵심 구현 흐름을 도식화하고 외부 공개 전에 선행문헌 검색 범위를 확장한다.
- KR/WO/US/EP 패밀리와 독립청구항별로 중첩 요소·누락 요소를 표시한다.
- 변리사와 신규성·진보성 검토 및 대상 국가의 실시 자유 검토를 각각 수행한다.
- 결과에 따라 청구범위, 구현 방식, 라이선스 또는 영업비밀 유지 대상을 결정한다.

사업 자산은 특허만이 아니다. 실제 장치 프로필, 재현 가능한 공격·오류 시나리오, 설치 자동화, 운영 로그 해석, 제조사·사업자 연동 경험도 축적한다. 특허 확보가 지연돼도 실증과 고객 검증은 분리하여 진행할 수 있다.

17 / 평가 설계

기본 보안·IPS·제안 기능을 같은 조건에서 비교한다

보안 효과는 서버 응답이 아니라 실제 모형 실행 여부까지 관찰해 판단한다. 아래 값은 달성 실적이 아닌 MVP 합격 목표다.

비교군	구성	목적
A	인증·TLS·ACP 를 구성한 Mobius4	기존 플랫폼 보안의 기준선
B	A + 네트워크 분리·Suricata IPS	일반 IPS 적용 효과
C	B + 의미/상태 정책 + 실행 가드	제안 기능의 추가 효과와 비용

시험	목표와 관찰값
치명 시나리오	사전에 지정한 위험 명령·우회·재실행 시험에서 실제 위험 동작 0 회
양방향 탐지/차단	공격·오류 총 200 건 이상. 차단 대상 공격의 차단률 목표 95% 이상; 센서 오류·실제 비상은 보존·경보·제어 제한의 적정 처리율 별도 평가
정상 운영	정상 요청 10,000 건 이상, 오차단률 목표 0.1% 이하; 센서 경보 손실 별도 확인
지연 / 처리량	100 개 가상 장치·총 100 요청/초의 동일 정상 요청 조건에서 p95(C 응답시간)−p95(B 응답시간) 목표 20ms 이하; 엔진 처리시간 별도 계측
경로 일관성	HTTP/MQTT, 그룹, 원격 전달, 알림, 장치 직접 접근 시나리오 포함
장애 / 복구	정책 서버 단절·허브 재시작·시계 오차·오래된 상태·감사 저장 실패 검증

장비 사양, 네트워크, TLS 위치, 메시지 크기, 정책 수, 부하 생성기와 난수 시드를 기록한다. 지연은 요청 승인과 물리 동작을 분리 측정하고 p50/p95/p99 를 함께 보고한다. 평균값만으로 제어 지연을 설명하지 않는다.

결과 해석

합성 시험에서 얻은 차단률을 실제 현장의 전체 공격 탐지율로 홍보하지 않는다. 실패한 시나리오와 범위 밖 경로도 결과에 함께 남긴다.

18 / 추진 일정

16 주 안에 실증 가능한 범위를 완성한다

프로토콜 수를 늘리기보다 인증·집행 경로·실행 검증을 먼저 완성한다.

기간	개발 / 검증	완료 기준
1~2 주	위협 모델, 고객 인터뷰, 데이터 흐름, 장치 프로필 정의	보호 경로·제외 범위·정상/위험 시나리오 합의
3~5 주	TLS/브로커 신원 매핑, 공통 유입 정책, 네트워크 분리	HTTP/MQTT 우회·장치 사칭·할당량 시험 통과
6~8 주	상향 신뢰 상태, 하향 정책, 실행 가드, 버전 관리	명령 만료·중복·상태 변경 시험 통과
9~11 주	키트 2 종, 관리자 화면, 감사·알림, 연계 시나리오	센서 → 서버 → 제어의 사건 흐름 재현
12~14 주	A/B/C 비교 실험, 장애·부하·오차단 평가	목표별 결과와 미달 원인, 수정 계획 확보
15~16 주	고객 실증, 설치 문서, 운영 인수, 사업 판단	고객 가치·지원 비용·특허 후속 검토와 다음 단계 결정

중간 의사결정

- 2 주: 고객 문제와 통제 가능한 경로가 없으면 대상 현장 또는 장치군을 재선정한다.
- 8 주: 실행 가드나 우회 통제를 확보하지 못하면 사전 차단 제품이라는 범위를 재검토한다.
- 14 주: 추가 보안 효과보다 오차단·지연·운영 부담이 크면 정책 범위를 축소하고 원인을 수정한다.
- 16 주: 실증 효과와 지불 의사가 모두 확인될 때 상용화를 위한 후속 투자를 결정한다.

일정의 전제

장치 API 접근과 테스트 환경을 2 주 내 확보하는 4 인 팀의 계획이다. 제조사 협의·현장 설치·인증 일정은 별도이며 지연 시 일정이 달라진다.

19 / 인력과 계획 예산

인력 중심의 MVP 예산을 산정한다

16 주를 계획상 4 개월로 환산한 가정이다. 아래 금액은 공급업체 견적이나 실구매 부품 가격이 아니며 VAT 를 제외한다.

역할	투입	주요 책임
기술 / 보안 리드	1 명 × 4 개월	위협 모델, 정책 의미, 구조·보안 검토
플랫폼 개발	1 명 × 4 개월	Mobius4 연동, 신원 매핑, 정책·감사 API
네트워크 / IoT 개발	1 명 × 4 개월	IPS·네트워크, 장치 어댑터, 키트·실행 검증
화면 / QA 개발	1 명 × 4 개월	운영 화면, 시험 자동화, 성능·장애 평가

비용 항목	계획 산식	금액
인건비	16 인월 × 500 만 원	8,000 만 원
시험 장비·키트 배정	계획 총액; 상세 BOM·견적 추후	600 만 원
호스팅·개발 환경	계획 총액	200 만 원
외부 검토·실증 지원	보안·특허 검토 등 계획 배정	800 만 원
소계		9,600 만 원
예비비	소계의 10%	960 만 원
총계		1 억 560 만 원

500 만 원/인월은 인건비 계획용 환산 단가다. 실제 급여·간접비 체계에 따라 다시 산정한다. 양산 설계, 제품 인증, 상용 설비 설치, 24 시간 관제, 장기 유지보수 계약은 이 MVP 예산에 포함하지 않는다.

관리 기준

단계별 결과물과 집행 비용을 함께 기록한다. 장치 종류를 늘리기 전에 두 번째 현장의 프로필 재사용률과 지원 시간을 측정해 확장 비용을 확인한다.

20 / 위험과 대응

기술·사업의 불확실성을 진행 기준으로 관리한다

가장 큰 위험은 탐지 알고리즘 부족만이 아니다. 우회 경로, 장치 의미 불일치, 오차단과 설치 비용이 사업 성과를 좌우할 수 있다.

위험	영향	대응 / 판단 기준
허브 우회 경로	차단된 명령이 다른 경로에서 실행	네트워크·브로커·직접 연결 조사, 허용 경로 고정, 침투 시험
인증 주체 매핑 실패	위조 Originator 를 정상 장치로 인식	인증 결과와 ID 결합, 자격증명 교체·폐기 시험
정책 오차단	정상 제어 중단·운영 불신	관찰 모드, 단계 배포, 정상 데이터 재생, 버전 롤백
검사 후 상태 변경	허용 판단 이후 위험 상태에서 실행	상태 버전·만료시간과 실행 직전 현장 재검증
서비스 장애	통신 단절 때 제어·감사 공백	캐시 정책, 로컬 버퍼, 장치별 기본 동작·비상 경로 검증
기존 제품과 중복	고객이 추가 제품을 구매할 이유 부족	같은 환경의 기존 대안과 효과·통합 시간·지원 비용 비교
특허·호환성 제약	개발 변경이나 사업화 지연	독립항·패밀리 검토, 제조사 API·라이선스 확인
장치별 통합 비용 증가	매출보다 지원비가 빠르게 증가	프로필 재사용률·설치시간·지원시간을 계약 전후 측정

상용화 이전 필수 결과

보호 범위가 문서화된 실증 환경, 재현 가능한 비교 실험, 운영 인수 문서, 고객의 지불 의사, 장치별 지원 비용을 확보한다. 이 조건들이 부족하면 범용 제품 출시에 앞서 대상과 기능을 다시 좁힌다.

21 / 기대 결과와 제안

개발의 목표는 보안 효과와 고객 가치를 입증하는 것이다

처음부터 "모든 IoT 를 보호하는 허브"를 약속하지 않는다. oneM2M 환경에서 반복 적용할 수 있는 정책 서비스의 타당성을 검증한다.

결과물	검수 가능한 증거
공통 보안 허브	HTTP/MQTT 보호 경로, 인증 매핑, IPS 연계, 설치·설정 문서
장치 안전 정책 서비스	프로필 2 종, 상·하향 연계 정책, 버전·승인·롤백, 실행 가드
실증 키트와 운영 화면	모형 2 종, 정상/위험 시연, 사건 흐름·차단 이유·복구 화면
검증 보고서	A/B/C 비교, 실제 실행 로그, 오차단·지연·장애·우회 결과
사업화 판단 자료	고객 인터뷰·실증 결과, 가격 가설, 지원 원가, 선행특허 후속 검토

착수 제안

16 주 MVP 를 추진하되 첫 2 주에 고객의 실제 데이터 흐름과 장치 연동 가능성을 확인한다. 구현은 기존 보안 기능의 정상 설정에서 시작하고, 상향 데이터 신뢰와 하향 실행 조건의 연계를 핵심 실증으로 삼는다. 키트 판매는 이 검증 결과 이후에 별도로 판단한다.

제안의 한 문장

oneM2M 통신을 이해하는 공통 보안 허브에 장치별 안전 정책을 결합하여, 신뢰하기 어려운 데이터와 위험한 제어가 실제 피해로 이어지는 경로를 줄인다.

문서의 근거 구분

확인 사실: 표준·저장소·공시·특허 원문에서 확인한 내용. 설계 제안: 아직 구현되지 않은 구조와 정책. 계획 가정: 일정·예산·가격·성능 목표. 미확인 사항: 특정 제품 판매량·마진, 신규성, 시장 규모, 고객 지불 의사. 현재 제안서에는 실측 성능이나 실제 고객 계약이 있는 것으로 표현하지 않았다.

첨부 논문은 배경 문헌으로 사용했다. 제공된 Quora·Reddit 링크는 원문을 충분히 검증하지 못해 수치·공격 빈도·시장성의 근거로 채택하지 않았다.

부록 A / 특허 서지정보

대표 선행문헌 5 건의 범위를 구분한다

특허 제목만으로 기술 범위를 판단하지 않고 등록공보의 독립청구항을 기준으로 읽었다. 아래는 예비 조사이며 권리상태 확정 자료가 아니다.

문헌 / 최초 출원인	우선일 / 공개→등록	확인 범위
KR102863685B1 **주식회사 에즈웰**	2025.05.14 등록공고 2025.09.24	독립항 1: oneM2M 변환·현장 AI·선택 전송·GUI. 별도 A 형 공개번호 미확인. [S13]
KR102889055B1 **주식회사 케이티**	2022.12.15 KR20240093019A → 2025.11.19 등록공고	독립항 1·6·8·13: 라우터 이상감시 모델 할당. [S14]
KR102419687B1 **숭실대학교 산학협력단**	2020.11.18 KR20220067897A → 2022.07.12 등록공고	독립항 1·7: PCA 단일 주성분 투영과 거리 기준 이상 탐지. [S15]
US11616795B2 **McAfee LLC**	2019.08.23 US20210058415A1 → 2023.03.28 등록	독립항 1·7·13·19: 통신 통계 이미지·persona. 차단은 종속항에도 기재. [S16]
US10629037B2 **IBM Corp.**	2018.04.24 US20190325717A1 → 2020.04.21 등록	독립항 1·8·15: 케이스 내부 광량 변화로 스마트락 침입 알림. 원격 명령 보안과 구별. [S17]

현재 권리자와 최초 출원인은 다를 수 있다. 미국 US11616795B2 의 Google 표시에는 담보권 사건이 포함되어 있어 단순 소유권 이전으로 설명하지 않았다. 한국·미국·유럽 등의 권리 범위도 동일하다고 가정하지 않는다.

후속 검토

기술 설계가 정해지면 독립항별 요소 대응표를 작성하고 공식 등록원부·심사기록·해외 패밀리를 확인한다. 특허성 검토와 실시 자유 검토는 서로 다른 질문으로 진행한다.

부록 B / 근거 자료 1·3

표준·코드·보안 제품

자료 확인 기준: 2026.09.22. 본문의 [S 번호]는 아래 원문과 연결된다. 제품 기능은 공급업체 설명이며, 실제 성능은 별도 검증 대상이다.

[S01] IoTKETI, Mobius4 v4.24.5 / 기준 커밋

HTTP·MQTT·reqPrim·noti·grp, docs/tls.md, docker-compose.yml 과 LICENSE 를 로컬 코드에서 확인.

원문 열기

[S02] oneM2M, Developer Guide — APIs

보안 등록·인증·접근제어·종단 간 보호 기능 설명.

원문 열기

[S03] oneM2M TS-0002 v5.3.0 §6.4

SER 보안 요구사항. 요구사항을 특정 제품의 구현 보장으로 해석하지 않음.

원문 열기

[S04] OISF, Suricata 8.0.4 — IPS concept

인라인 IPS 의 허용·차단 규칙과 배치 개념.

원문 열기

[S05] OISF, Suricata 8.0.4 — MQTT keywords

MQTT 헤더·토픽·메시지 등 검사 가능한 필드.

원문 열기

[S06] AWS, Device Defender Detect availability change

2026.08.31 신규 고객 제공 종료; 기존 고객 이용 지속, Audit 는 영향 없음.

원문 열기

[S07] Fortinet, Advanced Threat Protection for ICS/OT

OT 프로토콜 DPI, 기능·값 기반 허용/거부, IPS. 제품 공개 기능 설명이며 성능 비교 결과가 아님.

원문 열기

부록 B / 근거 자료 2·3

시장·실적·문헌

자료 확인 기준: 2026.09.22. 본문의 [S 번호]는 아래 원문과 연결된다. 제품 기능은 공급업체 설명이며, 실제 성능은 별도 검증 대상이다.

[S08] Nozomi Networks, Guardian firewall integration

수동 탐지와 외부 방화벽 정책 삽입·세션 제어의 결합.

원문 열기

[S09] Verisure, Q4 and FY2025 Results; Annual Report 2025

2026.02.12 실적. 매출 €3,745.4m·조정 EBIT €952.9m; 연말 약 620 만 고객, Q4 신규 설치 22.4 만.

원문 열기 | 보조 원문 열기

[S10] Allegion, FY2025 Results

2026.02.17 실적. 매출 US$4,067.3m·영업이익 US$859.5m·GAAP 영업이익률 21.1%.

원문 열기

[S11] Resideo, Q4 and FY2025 Financial Results

2026.02.24 실적. 매출 US$7,472m·총이익 US$2,196m·영업이익 US$607m·순손실 US$527m.

원문 열기

[S12] Kim, H.; Lee, H.; Lee, Y. (2020), IoT 보안 문헌조사

A Survey Analysis of Internet of Things Security Issues and Combined Service, JKSCI 25(8), pp.73–79. 첨부 KCI_FI002615826.pdf.

원문 열기

[S13] KR102863685B1, 주식회사 에즈웰

ICT 망을 이용한 산업 안전 관리 시스템에서 oneM2M 프로토콜 변환 및 경량화된 AI Edge Computing 기능을 내장한 게이트웨이 장치. 독립항 1.

원문 열기

부록 B / 근거 자료 3·3

특허·구현·운영 참고

자료 확인 기준: 2026.09.22. 본문의 [S 번호]는 아래 원문과 연결된다. 제품 기능은 공급업체 설명이며, 실제 성능은 별도 검증 대상이다.

[S14] KR102889055B1, 주식회사 케이티

IoT 라우터의 이상 감시를 위한 이상 감시 장치 및 방법. 독립항 1·6·8·13.

원문 열기

[S15] KR102419687B1, 숭실대학교 산학협력단

IoT 를 기반으로 하는 이상 탐지 방법 및 그 장치. 독립항 1·7.

원문 열기

[S16] US11616795B2, McAfee LLC 최초 출원

Methods and apparatus for detecting anomalous activity of an IoT device. 독립항 1·7·13·19.

원문 열기

[S17] US10629037B2, IBM Corp. 최초 출원

Smart lock intrusion detection. 독립항 1·8·15, 케이스 내부 광량 변화 기반 알림.

원문 열기

[S18] Mobius4, TLS 및 라이선스 문서

서버 TLS 와 클라이언트 신원 결합의 차이; BSD 3-Clause 배포 조건은 같은 커밋의 LICENSE 참조.

원문 열기

[S19] oneM2M TS-0040 v5.0.2 §6.5

Modbus interworking. Blocking subscription 을 이용한 외부 작업과 자원 갱신 조율.

원문 열기

[S20] Firewalla, Device Active Protect

장치 행동을 학습하고 필요한 목적지를 허용하는 네트워크 정책. 지원 하드웨어·배치 모드 조건 있음.

원문 열기